Report

XSS External Entity Injection

Suyash A Gunjal

External Entity Injection

What is External Entity Injection?

What is external entity injection?

XML external entity injection (also known as XXE) is a web security vulnerability that allows an attacker to interfere with an application's processing of XML data.

It often allows an attacker to view files on the application server filesystem, and to interact with any back end or external systems that the application itself can access.

In some situations, an attacker can escalate an XXE attack to compromise the underlying server or other back-end infrastructure, by leveraging the XXE vulnerability to perform server-side request forgery (SSRF) attacks.

What Is the Impact of XXE Attacks?

XXE attacks:

- **Disclosing local files**: threat actors can disclose files containing sensitive data, like passwords, using file: schemes or relative paths in the system identifier.
- **Expanding the attack**: XXE attacks rely on the application that processes the XML document. Threat actors can use this trusted application to move to different internal systems.
- **Remote code execution**: if the XML processor library is vulnerable to client-side memory corruption, a threat actor can dereference a malicious URI to allow arbitrary code execution under the application account.
- **Impacting application availability**: some XML attacks might allow actors to access local resources that do not stop returning data. If too many processes or threads are not released, it can negatively impact application availability.

XXE Attack Example:

XML files might contain document type definitions (DTDs) that allow defining and consuming XML entities. It is possible to define external entities using URIs. The XML parser will process this URI and add the resulting content into an XML document.

REQUEST:

```
POST http://example.com/xml HTTP/1.1
<?xml version="1.0" encoding="ISO-8859-1"?>
<!DOCTYPE external [
  <!ELEMENT external ANY>
  <!ENTITY xxe SYSTEM
  "file:///etc/system.d">
]>
<external>
  &xxe;
</external>
```

RESPONSE:

```
HTTP/1.0 200 OK
[Unit]
Description=NGINX HTTP server
After=syslog.target network.target remote-fs.target nss-lookup.target
[Service]
Type=forking
PIDFile=/run/nginx.pid
ExecStartPre=/usr/sbin/nginx -t
(...)
```

Ways to Prevent External Entity Injection (XXE):

Disable DTDs (Document Type Definitions)

- XXE exploits usually rely on <!DOCTYPE> declarations.
- Disabling DTDs blocks external and internal entities.

Disable External Entity Resolution

- Prevent the XML parser from accessing external files, URLs, or system identifiers.
- Stops attackers from loading malicious external entities.

Use Secure and Updated XML Parsers

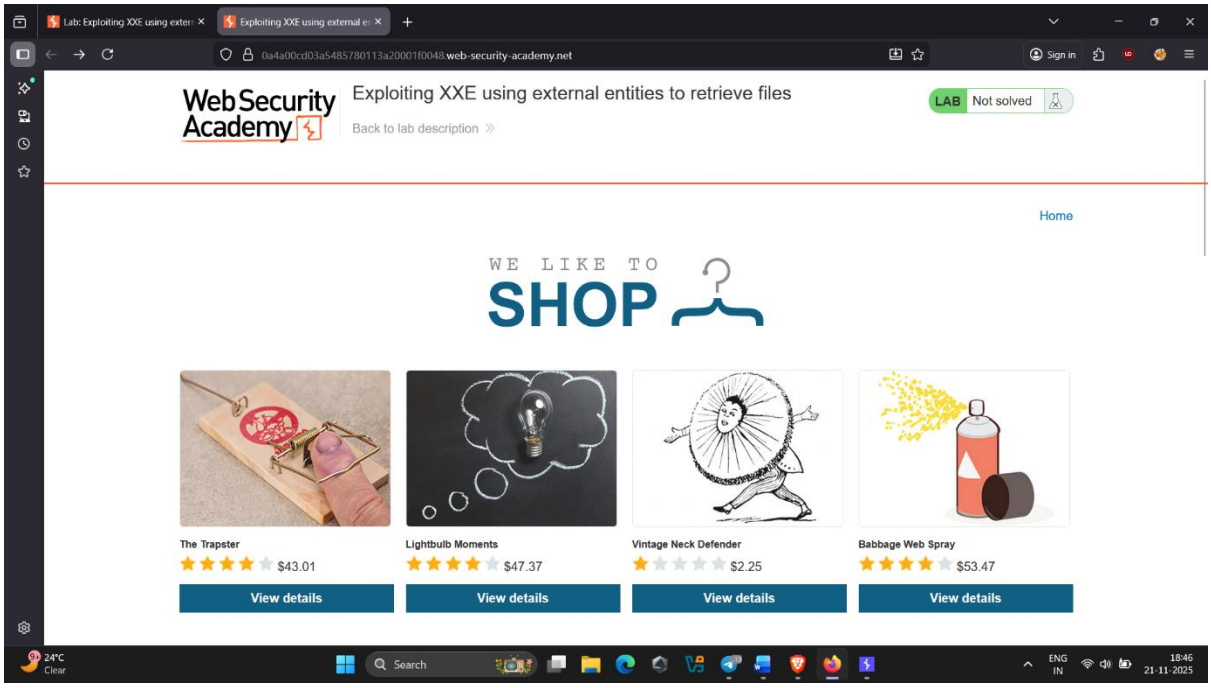
- Many old parsers have insecure defaults.
- Use versions that have XXE protections enabled by default.

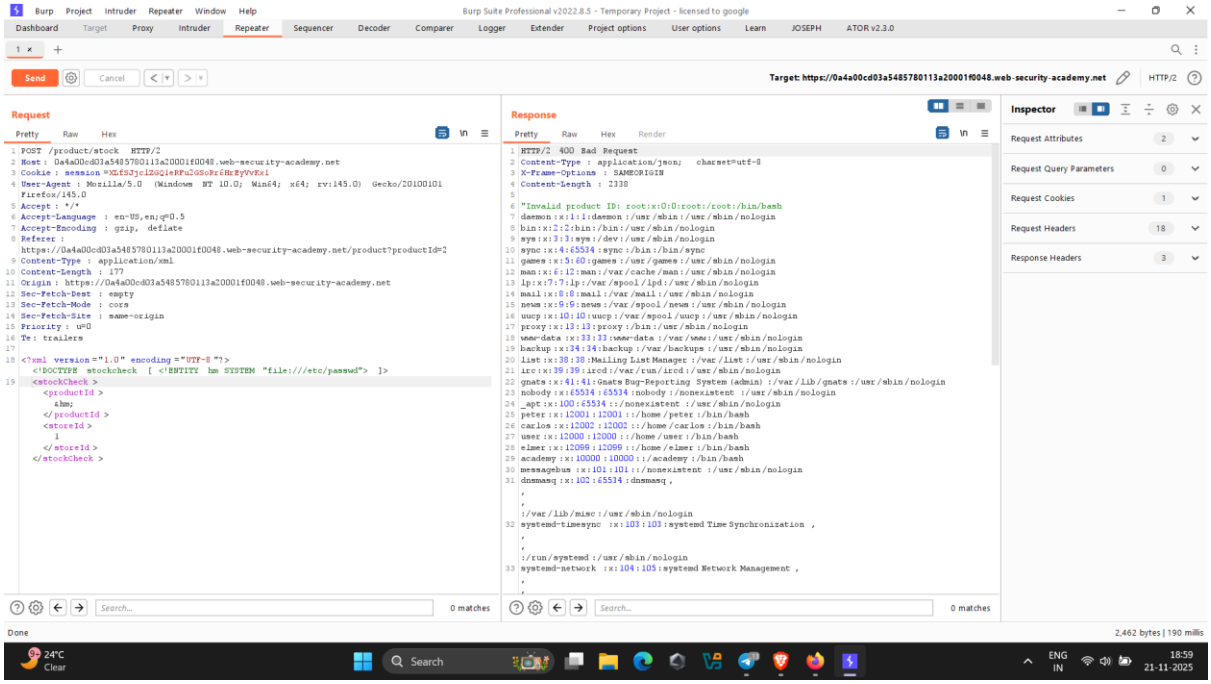
Use XML Features Like "Secure Processing"

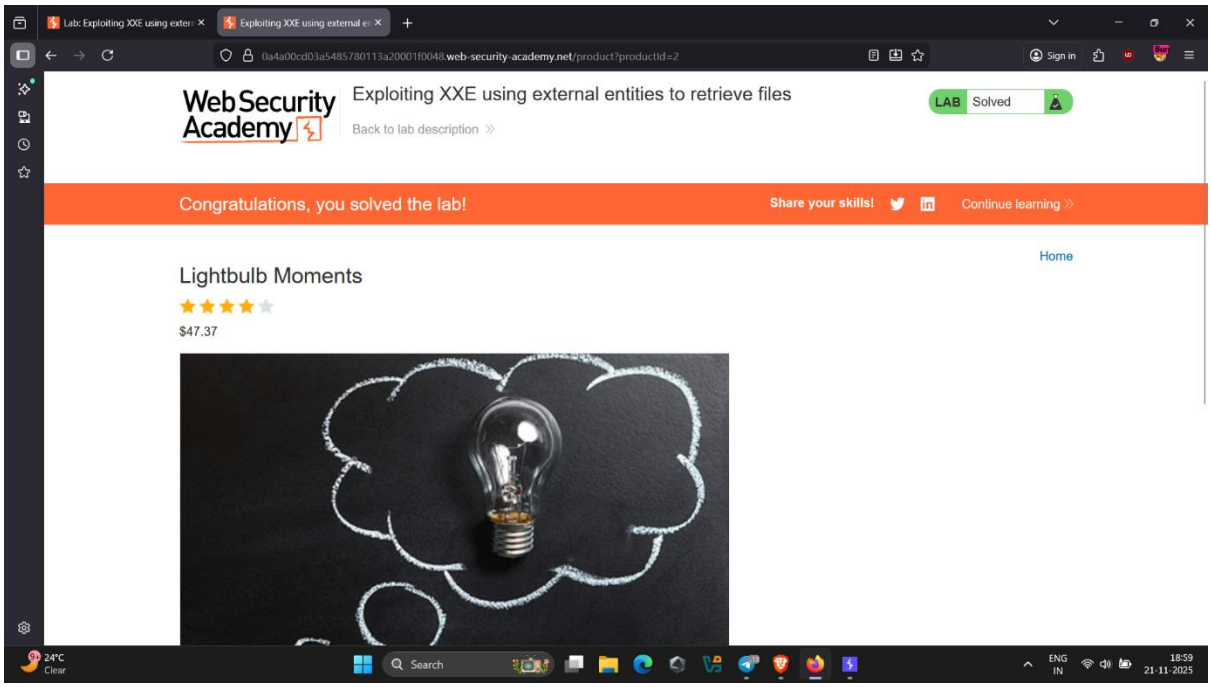
- Enforces limits on entity expansion, network calls, and overall parsing behaviour.

Validate and Sanitize Incoming XML Input

- Reject XML that contains <!DOCTYPE>, <!ENTITY>, or suspicious structures.
- Accept only well-structured and expected XML formats.







References:

https://owasp.org/www-community/vulnerabilities/XML_External_Entity_(XXE)_Processing

https://portswigger.net/web-security/xxe